

Kounouz Alafiya

كنوز العافية

Documentation complète de A à Z

Plateforme de confiance, vérification et traçabilité du miel Phase 1 —
Version prête au déploiement · Septembre 2026

Phase 1 · 17/09/2026

Sommaire

- | | |
|---|---|
| 1. Ce qu'est l'application | 13. Ventes, commission et règlements |
| 2. Le principe fondateur | 14. Notifications |
| 3. Architecture technique | 15. Journal d'audit |
| 4. Les 5 types d'utilisateurs | 16. Modèle de données |
| 5. La chaîne de confiance de bout en bout | 17. Machines à états |
| 6. Fonctionnalités — Portail Producteur | 18. Sécurité |
| 7. Fonctionnalités — Portail Agent Terrain | 19. Déploiement pas à pas |
| 8. Fonctionnalités — Portail Équipe de Vérification | 20. Comptes et données de démonstration |
| 9. Fonctionnalités — Console Admin | 21. Scénario complet de bout en bout |
| 10. Fonctionnalités — Site public et Consommateur | 22. Tests d'acceptation automatisés |
| 11. QR dynamique et vérification publique | 23. Exploitation au quotidien |
| 12. Anti-contrefaçon | 24. Hors périmètre Phase 1 |

1. Ce qu'est l'application

Kounouz Alafiya est une plateforme unique qui relie, dans une seule chaîne de données vérifiable :

- la **demande de vérification** d'un producteur de miel ;
- la **collecte contrôlée** d'un échantillon par un agent Kounouz ;
- le **scellé sécurisé** et la **chaîne de custody** de cet échantillon ;
- l'**analyse laboratoire** et l'**échantillon de référence** conservé par Kounouz ;
- la **décision de vérification** prise par l'équipe Kounouz ;
- le **lot vérifié**, l'**emballage Kounouz**, le **produit** et ses **déclinaisons (SKU)** ;
- le **QR code dynamique** imprimé sur le pot ;
- le **scan du consommateur**, la **page de vérification publique**, les **statistiques** et la **surveillance anti-contrefaçon**.

Le site public existant (vitrine, marketplace, présentation des produits) est conservé tel quel. La plateforme ajoute les portails authentifiés et la chaîne de vérification autour de lui.

Une plateforme · Cinq types d'utilisateurs · Un modèle de données partagé.

2. Le principe fondateur

Kounouz contrôle la vérification. Le producteur la demande.

Ce principe n'est pas une intention : il est **appliqué par le serveur**.

Le producteur :

- **peut** créer une demande de vérification et suivre son avancement ;
- **ne peut pas** enregistrer un échantillon ;
- **ne peut pas** téléverser, modifier ni approuver un résultat de laboratoire ;
- **ne peut pas** poser ou modifier un scellé ;
- **ne peut pas** prendre la décision de vérification ;
- **ne peut pas** créer un lot, un emballage, un produit ni un QR code.

Kounouz contrôle l'échantillonnage, le scellé, la custody, l'analyse, la conservation de l'échantillon de référence, la décision, l'emballage, la création du produit et la publication.

Ces refus sont vérifiés automatiquement (voir §22 Tests d'acceptation) : une requête envoyée directement à l'API, en contournant l'interface, est rejetée par le serveur avec un code `403`.

3. Architecture technique

Vue d'ensemble



Le front et l'API sont servis derrière **une seule origine** : le navigateur ne voit que `nginx`, qui relaie `/api` vers le backend. Il n'y a donc **aucun CORS** en production, et l'IP du visiteur est transmise au backend (`X-Forwarded-For`) pour alimenter le journal des scans.

Stack

Couche	Technologie
Frontend	React 19, TypeScript, Vite 6, Tailwind CSS 4, React Router 7, TanStack Query
Internationalisation	i18next — français, arabe, anglais
Backend	NestJS 12, TypeScript, Passport JWT
Base de données	PostgreSQL 16 + Prisma 6 (12 migrations)
Documentation API	Swagger — /api/docs
Conteneurisation	Docker + Docker Compose
Serveur web	nginx 1.27 (alpine)

Modules backend

[auth](#) · [producers](#) · [producer-documents](#) · [verification-requests](#) · [samples](#) · [seals](#) · [field-agent](#) · [laboratory](#) · [verifications](#) · [verification-portal](#) · [batches](#) · [packaging](#) · [categories](#) · [products](#) · [qr-codes](#) · [anti-fraud](#) · [sales](#) · [reports](#) · [admin](#) · [notifications](#) · [support](#) · [contact](#) · [uploads](#) · [audit](#) · [health](#)

Organisation du dépôt

```
kounouz affia/
├─ backend/                API NestJS
│  └─ prisma/
│     └─ schema.prisma     modèle de données complet
│     └─ migrations/      12 migrations versionnées
│     └─ seed*.ts          données de démonstration
│  └─ src/                un dossier par domaine métier
│  └─ Dockerfile           image de production (multi-étapes)
│  └─ .env.example         variables documentées
├─ frontend/              application React
│  └─ src/
│     └─ components/       site public existant
│     └─ pages/            connexion, inscription, vérification publique
│     └─ portals/          producer · agent · verifier · admin
│     └─ design-system/    composants partagés
│     └─ i18n/             fr · ar · en
│  └─ Dockerfile           build + nginx
│  └─ nginx.conf           SPA + relais /api
├─ scripts/
│  └─ acceptance.mjs       tests d'acceptation post-déploiement
├─ docker-compose.yml      pile complète
├─ .env.deploy.example     modèle de configuration
├─ DOCUMENTATION.md        ce fichier
├─ GUIDE_UTILISATION.md    guide utilisateur
└─ README.md               notes techniques
```

4. Les 5 types d'utilisateurs

Exactement cinq rôles existent. **Le laboratoire et le transporteur ne sont pas des types d'utilisateurs** : le laboratoire est une fiche d'organisation reliée aux analyses, le transport est un événement de chaîne de custody.

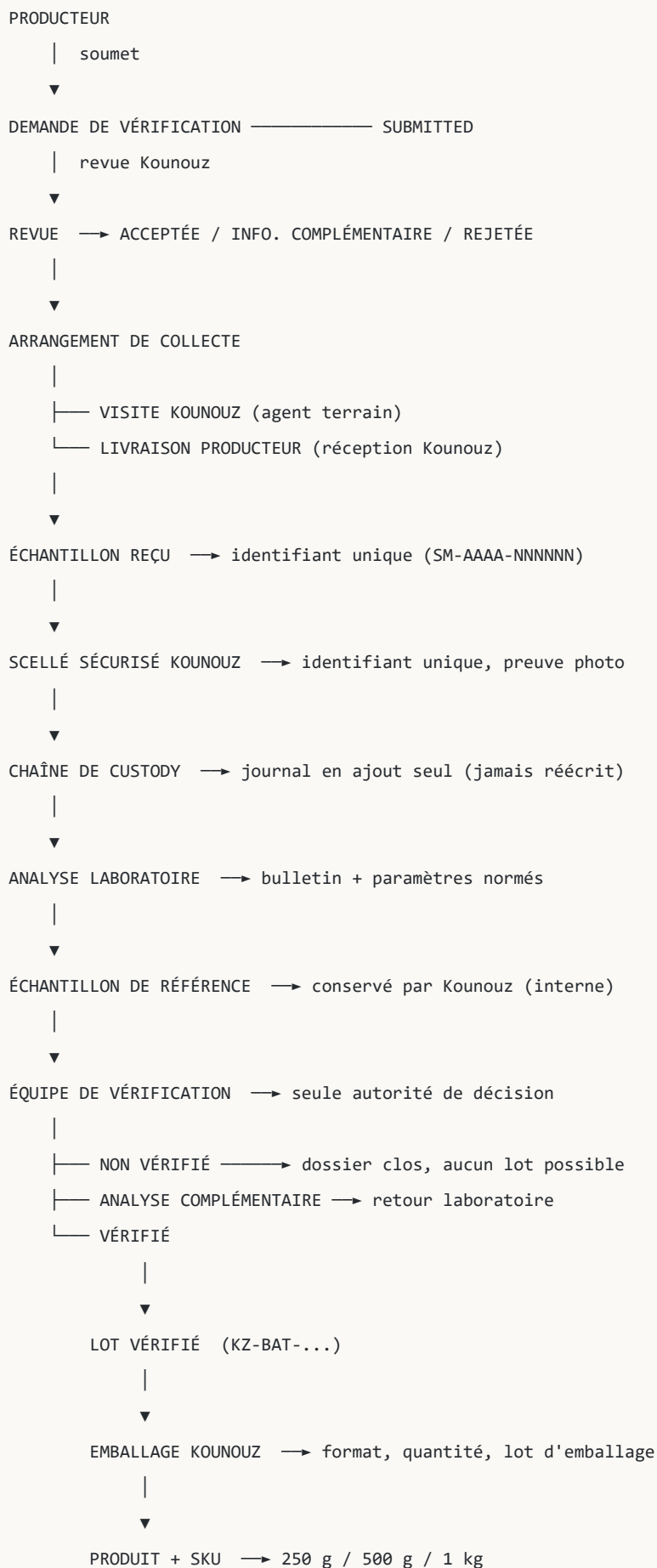
Rôle	Responsabilités	Ne peut pas
Producteur	Profil, ruchers, documents, demandes de vérification, suivi, consultation de ses lots/produits, ventes et gains	Enregistrer un échantillon, modifier une analyse, poser un scellé, décider, créer un produit
Agent Terrain	Missions assignées, collecte, échantillon, scellé, preuves, chaîne de custody	Décider de la vérification
Équipe de Vérification	Revue des demandes, gestion des échantillons, laboratoire, échantillons de référence, décision , lots, emballage, produits, QR	— (autorité opérationnelle)
Admin	Utilisateurs et rôles, producteurs, laboratoires, analyses, journal d'audit, paramètres, overrides audités	— (tout override est journalisé)
Consommateur	Navigation, achat, scan de QR, page de vérification publique	Accéder à toute donnée interne

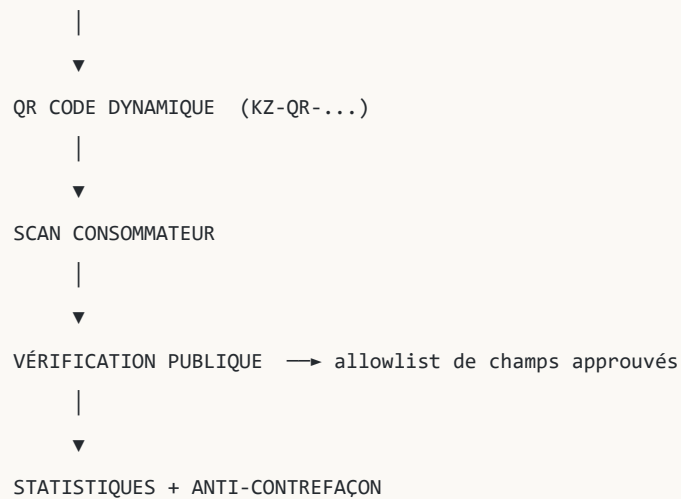
Matrice des permissions appliquée

✓ autorisé · V lecture seule · — aucun accès · A* override admin audité

Action	Producteur	Agent	Vérification	Admin	Consommateur
Créer une demande de vérification	✓	—	✓	A*	—
Examiner une demande	V (la sienne)	—	✓	A*	—
Planifier / assigner une collecte	—	—	✓	A*	—
Créer / enregistrer un échantillon	—	✓ (assigné)	✓	A*	—
Enregistrer un scellé sécurisé	—	✓ (assigné)	✓	A*	—
Enregistrer un événement de custody	—	✓ (assigné)	✓	A*	—
Saisir / modifier un résultat de laboratoire	—	—	✓	A*	—
Gérer un échantillon de référence	—	—	✓	A*	—
Prendre la décision de vérification	—	—	✓	A*	—
Créer un lot vérifié	—	—	✓	A*	—
Enregistrer un emballage	—	—	✓	A*	—
Créer un produit / SKU	—	—	✓	A*	—
Générer / suspendre un QR	—	—	✓	A*	—
Voir la vérification publique	—	—	—	V	✓
Voir ses propres ventes et gains	✓	—	—	✓	—
Voir toutes les ventes	—	—	✓	✓	—
Statistiques de scan	—	—	✓	✓	—
Gérer les alertes anti-contrefaçon	—	—	✓	✓	—
Journal d'audit	—	—	V (limité)	✓	—
Utilisateurs et rôles	—	—	—	✓	—

5. La chaîne de confiance de bout en bout





Aucun raccourci n'est possible. Le serveur refuse toute étape dont les prérequis ne sont pas satisfaits : pas de lot sans décision **VERIFIED**, pas de produit sans emballage, pas de QR actif sans produit publiable.

6. Fonctionnalités — Portail Producteur

Adresse : **/producteur** · Connexion avec un compte de rôle **PRODUCER**.

Écran	Adresse	Contenu
Tableau de bord	<code>/producteur</code>	Synthèse : demandes en cours, échantillons, lots, produits, ventes récentes
Mes demandes	<code>/producteur/demandes</code>	Liste filtrable de toutes les demandes avec leur statut réel
Nouvelle demande	<code>/producteur/demandes/nouvelle</code>	Formulaire : type de miel, quantité estimée, période de récolte, rucher, documents
Détail d'une demande	<code>/producteur/demandes/:id</code>	Avancement, échanges avec Kounouz, informations complémentaires demandées
Mes échantillons	<code>/producteur/echantillons</code>	Lecture seule — suivi des échantillons prélevés par Kounouz
Mes lots	<code>/producteur/lots</code>	Lecture seule — lots vérifiés issus de ses miels
Mes produits	<code>/producteur/produits</code>	Lecture seule — produits commerciaux créés par Kounouz
Ventes	<code>/producteur/ventes</code>	Tableau de bord commercial par SKU
Historique des ventes	<code>/producteur/ventes/historique</code>	Détail des commandes le concernant
Mes gains	<code>/producteur/ventes/gains</code>	Chiffre d'affaires brut, commission Kounouz, net producteur
Règlements	<code>/producteur/ventes/reglements</code>	Périodes de règlement et statut de paiement
Notifications	<code>/producteur/notifications</code>	Événements du dossier
Mon profil	<code>/producteur/profil</code>	Identité, exploitation, ruchers, documents, coordonnées bancaires
Paramètres	<code>/producteur/parametres</code>	Langue, mot de passe, 2FA, e-mail, préférences de notification
Aide	<code>/producteur/aide</code>	Guide et tickets de support

Points conformes au cahier des charges :

- l'écran **Nouvelle demande** ne propose **aucun téléversement de résultat de laboratoire** — les documents d'exploitation restent dans le profil ;
- **Mes échantillons**, **Mes lots** et **Mes produits** n'offrent aucun bouton de création : ce sont des vues de suivi ;
- un producteur ne voit **jamais** les données d'un autre producteur : la propriété est déduite du jeton d'authentification, jamais d'un paramètre fourni par le client.

7. Fonctionnalités — Portail Agent Terrain

Adresse : `/agent` · Interface **pensée pour le mobile** (travail sur le terrain).

Écran	Adresse	Contenu
Tableau de bord	/agent	Missions du jour, tâches en attente
Mes missions	/agent/missions	Missions assignées et missions disponibles à réclamer
Détail de mission	/agent/missions/:id	Producteur, rucher, créneau, équipement, reprogrammation
Collecte	/agent/collecte	Point d'entrée des collectes en cours
Assistant de collecte	/agent/collecte/:assignmentId	Parcours guidé : quantité, date/heure, position, photos, notes
Scellés	/agent/scelles	Enregistrement et consultation des scellés posés
Traçabilité	/agent/tracabilite	Chaîne de custody des échantillons collectés
Détail custody	/agent/tracabilite/:id	Historique en ajout seul d'un échantillon
Mes visites	/agent/visites	Historique des visites réalisées
Rapports	/agent/rapports	Activité de l'agent
Messages	/agent/messages	Échanges avec Kounouz
Notifications	/agent/notifications	Nouvelles assignations

Règles appliquées :

- une collecte ne peut démarrer que depuis une **mission assignée** (ou une mission disponible réclamée) — jamais librement ;
- l'agent ne voit et ne modifie **que ses propres** échantillons ;
- les événements de custody historiques sont **immuables** : une correction ajoute un nouvel événement, elle n'écrase jamais le précédent ;
- l'agent **n'a aucun accès** aux écrans de décision de vérification.

8. Fonctionnalités — Portail Équipe de Vérification

Adresse : /verificateur · C'est le cœur opérationnel de Kounouz.

Écran	Adresse	Contenu
Tableau de bord	<code>/verificateur</code>	Charge de travail, dossiers en attente, alertes
Centre de vérification	<code>/verificateur/centre</code>	Vue unifiée de tous les dossiers en cours
Revue des demandes	<code>/verificateur/demandes</code>	Accepter · demander des informations · rejeter · planifier la collecte
Gestion des échantillons	<code>/verificateur/echantillons</code>	Réception, statut, custody, affectation au laboratoire
Laboratoire	<code>/verificateur/laboratoire</code>	Dossiers d'analyse, saisie des paramètres normés, bulletins, pièces jointes
Échantillons de référence	<code>/verificateur/etalons</code>	Enregistrement et conservation des échantillons de référence
Décision de vérification	<code>/verificateur/decisions</code>	VÉRIFIÉ · NON VÉRIFIÉ · ANALYSE COMPLÉMENTAIRE avec grille d'évaluation
Lots vérifiés	<code>/verificateur/lots</code>	Création et suivi des lots
Détail d'un lot	<code>/verificateur/lots/:id</code>	Vue opérationnelle complète : lot, vérification, documents, QR, traçabilité
Emballage	<code>/verificateur/emballage</code>	Enregistrement de l'emballage Kounouz (format, quantité, lot d'emballage)
Produits	<code>/verificateur/produits</code>	Création du produit commercial et de ses SKU
Génération de QR	<code>/verificateur/qr</code>	Campagnes de génération de QR uniques
Gestion des QR	<code>/verificateur/qr/gestion</code>	Recherche, filtres, inspection, export, activation/suspension
Rapports	<code>/verificateur/rapports</code>	Rapports opérationnels et anti-fraude
Équipe	<code>/verificateur/equipe</code>	Gestion de l'équipe (accès restreint)

Règles appliquées :

- la **décision appartient exclusivement** à ce portail (et à un override admin audité) ;
- une décision `VERIFIED` ne peut être confirmée que si les **preuves requises** sont présentes ;
- un dossier reste **modifiable en brouillon** (`isDraft`) : tant qu'il n'est pas confirmé, il n'engage pas Kounouz, ne notifie personne et ne crée aucun lot ;
- l'écran **Laboratoire** gère le flux d'analyse **sans laisser entendre que Kounouz est lui-même un laboratoire accrédité** ;
- seul un lot `VERIFIED` peut entrer en emballage ; seul un lot emballé peut devenir un produit commercial.

9. Fonctionnalités — Console Admin

Adresse : `/admin`

Écran	Adresse	Contenu
Tableau de bord	/admin	Santé du système, pipeline de vérification, activité
Utilisateurs et rôles	/admin/utilisateurs	Création, rôles, activation/désactivation, réinitialisation de mot de passe, export
Producteurs	/admin/producteurs	Vue d'ensemble, statuts, création, export
Détail producteur	/admin/producteurs/:id	Dossier complet, documents, historique
Laboratoires	/admin/laboratoires	Fiches de laboratoires, accréditations, statut
Demandes	/admin/demandes	Toutes les demandes de vérification
Échantillons	/admin/echantillons	Tous les échantillons et leur custody
Scellés	/admin/scelles	Registre des scellés
Laboratoire	/admin/laboratoire	Registre des analyses
Vérification	/admin/verification	Registre des décisions
Lots	/admin/lots	Tous les lots
Emballage	/admin/emballage	Opérations d'emballage
Produits / Catégories	/admin/produits , /admin/categories	Catalogue commercial
QR codes	/admin/qr-codes	Registre complet des QR
Commandes	/admin/commandes	Commandes consommateurs
Règlements	/admin/reglements	Règlements producteurs
Statistiques de scan (AN01)	/admin/analyses/scans	Volume, validité, répartition temporelle, signaux de sécurité
Alertes anti-contrefaçon (AN02)	/admin/analyses/alertes	Alertes, gravité, preuves, revue humaine, résolution
Analytique métier (AN03)	/admin/analyses/verification	Entonnoir de vérification, lots, produits, ventes, tendances
Journal d'audit	/admin/journal	Traçabilité des actions sensibles, statistiques, export
Rapports	/admin/rapports	Rapports opérationnels exportables
Support	/admin/support	Boîte de réception des tickets et messages de contact
Paramètres	/admin/parametres	Configuration de la plateforme

Tout **override administratif** d'une décision opérationnelle sensible crée une entrée dans le journal d'audit comportant l'acteur, l'horodatage, l'action, l'entité visée, la valeur précédente, la nouvelle valeur et le motif.

10. Fonctionnalités — Site public et Consommateur

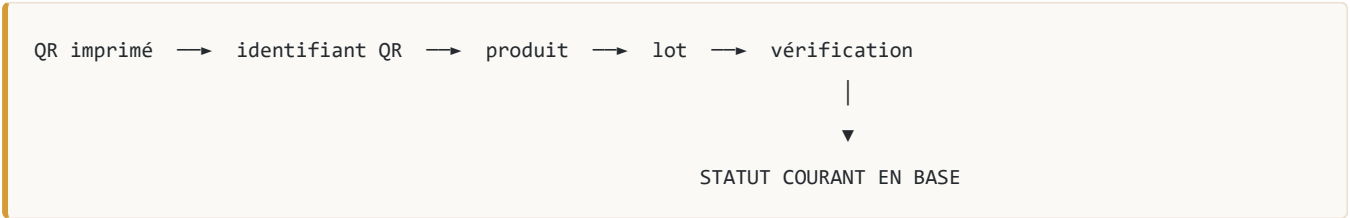
Le site vitrine existant est **préservé** : identité de marque, navigation, présentation des produits, comportement responsive.

Écran	Adresse	Contenu
Vitrine	/	Accueil, histoire, processus qualité, sections éditoriales
Produits	/ (marketplace)	Catalogue, fiches produit, panier
Vérification publique	/verify/:identifiant	Résultat d'un scan de QR
Guide	/guide	Guide intégré à l'application
Connexion	/connexion	Accès aux portails
Inscription producteur	/inscription/producteur	Création d'un compte producteur
Inscription client	/inscription/client	Création d'un compte consommateur

Le consommateur peut naviguer, acheter, scanner un QR et signaler une étiquette abîmée ou suspecte. Il n'a **aucun accès** aux données internes — ce point est vérifié automatiquement par les tests d'acceptation.

11. QR dynamique et vérification publique

Le QR n'est pas la source de vérité — la base l'est



Conséquence essentielle : **un QR déjà imprimé n'a jamais besoin d'être réimprimé**. Si un lot est suspendu ou rappelé, le même QR affiche immédiatement le nouveau statut.

Trois états publics distincts :

Situation	Réponse publique
Produit publié, lot actif	VERIFIED — page de vérification complète
Produit suspendu ou lot suspendu	SUSPENDED — mise en garde explicite
Lot rappelé	RECALLED — prime sur toute autre information
QR inconnu ou désactivé	404 générique — et le scan est journalisé comme signal de contrefaçon

Champs publiés (allowlist stricte)

Seuls ces champs sortent de l'API publique :

- **Produit** : nom, description, images, gamme, catégorie
- **Producteur / source** : nom, nom de l'exploitation, région
- **Lot** : code de lot, type de miel, date de production, date de durabilité, origine
- **Vérification** : statut, date de vérification
- **Analyse** : date, statut, nom du laboratoire, **paramètres normés du bulletin** (valeur, unité, conformité, plage de référence)

Ce qui n'est jamais publié

- les **notes de décision** du vérificateur ;
- les **notes internes** et la **conclusion** rédigées par l'analyste ;
- le JSON libre du bulletin (**results**) ;
- les détails de l'**échantillon de référence** et de son stockage ;
- la **chaîne de custody** détaillée et les identifiants de scellé ;
- l'identité des employés, les données de contact privées ;
- les **données d'enquête** anti-contrefaçon.

Cette séparation est testée automatiquement : le test d'acceptation échoue si l'un de ces champs réapparaît dans la réponse publique.

12. Anti-contrefaçon

Chaque scan est journalisé, **y compris sur un identifiant inconnu**. Les règles déterministes produisent des alertes internes :

- scans répétés dans un intervalle anormalement court ;
- répartition géographique inhabituelle ;
- scans sur QR invalide ou non enregistré ;
- comportement évoquant un QR dupliqué ou copié ;
- signalement d'étiquette abîmée par un consommateur ;
- anomalies de scan en masse.

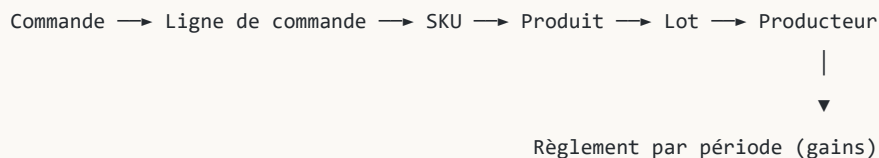
Cycle de vie d'une alerte :

DÉTECTÉE → OUVERTE → EN REVUE → CONFIRMÉE / ÉCARTÉE → RÉSOLUE

Principe non négociable : **une alerte est un signal interne, jamais une accusation**. Aucune suspension automatique de producteur n'est déclenchée par un score ; une revue humaine est requise avant toute action opérationnelle.

13. Ventes, commission et règlements

Les ventes sont modélisées **au niveau SKU** (`ProductVariant`), car les formats diffèrent (250 g, 500 g, 1 kg) et doivent rester mesurables séparément.



Calcul des gains producteur :

Élément	Source
Unités vendues	Lignes de commande par SKU
Chiffre d'affaires brut	Somme des lignes
Taux de commission Kounouz	Configurable — variable <code>KOUNOUZ_COMMISSION_RATE</code>
Montant de commission	Brut × taux
Net producteur	Brut – commission

Le taux de commission **n'est jamais codé en dur** : il est lu dans la configuration (par défaut `0.2`, soit 20 %) et le règlement conserve la base de calcul appliquée.

14. Notifications

Les notifications in-app sont générées à partir d'événements métier réels, avec une sélection de destinataires fondée sur le rôle et la propriété.

Type	Destinataire	Déclencheur
REQUEST_ACCEPTED	Producteur	Sa demande est acceptée
COLLECTION_ASSIGNED	Agent Terrain	Une mission lui est assignée
COLLECTION_AVAILABLE	Agents Terrain	Une mission est disponible
SAMPLE_RECEIVED	Producteur	Son échantillon est réceptionné
ANALYSIS_COMPLETED	Producteur	L'analyse est terminée
VERIFICATION_RESULT	Producteur	La décision est rendue
BATCH_CREATED	Producteur	Un lot vérifié est créé
PRODUCT_PUBLISHED	Producteur	Son produit est publié
NEW_ORDER	Producteur	Une commande concerne son produit
PAYOUT_PAID	Producteur	Un règlement est payé
DOCUMENT_REVIEWED	Producteur	Un document est examiné
COUNTERFEIT_ALERT	Kounouz	Une alerte est levée
SUPPORT_TICKET_UPDATE	Auteur du ticket	Réponse au ticket

Chaque utilisateur peut désactiver certains types depuis ses paramètres.

15. Journal d'audit

Sont journalisés : les transitions d'état sensibles, les décisions de vérification, les changements de statut de QR, les overrides administratifs, les modifications de rôles et les actions impactant les règlements.

Chaque entrée conserve : acteur, rôle, action, type et identifiant d'entité, statut précédent, nouveau statut, horodatage, motif, et métadonnées de requête (IP, session) lorsque c'est légalement approprié.

Pour les enregistrements de custody et de sécurité, l'événement original est **conservé** et une correction ajoute un nouvel événement : les faits historiques ne sont jamais réécrits.

Le journal d'audit **n'est jamais exposé aux consommateurs**.

16. Modèle de données

Chaîne principale :

User → Producer → VerificationRequest → Sample → Seal → SampleEvent
→ LaboratoryAnalysis (+ LabTestResult, LabAnalysisFile)
→ ReferenceSample → Verification → Batch → Packaging
→ Product → ProductVariant (SKU) → QRCode → QRScan → CounterfeitAlert

Chaîne commerciale :

Order → OrderItem → ProductVariant → Product → Batch → Producer → Payout

Entités transversales : Notification , AuditLog , SupportTicket , ContactMessage , Categorie , Laboratory , LaboratoryAccreditation , CollectionAssignment , ReferenceHoney , ProducerDocument , Consumer .

Contraintes d'unicité

Codes lisibles uniques et protégés : code producteur, numéro de demande, identifiant d'échantillon, identifiant de scellé (un seul scellé actif par échantillon), code d'analyse, identifiant d'échantillon de référence, code de vérification, code de lot, identifiant de produit, SKU, identifiant et numéro de série de QR.

Intégrité référentielle

Les relations de traçabilité réglementée utilisent **onDelete: Restrict** : **on ne supprime pas en cascade un historique de traçabilité**. Les événements de custody, les scans et les décisions restent des enregistrements historiques.

17. Machines à états

Demande de vérification

DRAFT → SUBMITTED → UNDER_REVIEW → ACCEPTED → COLLECTION_SCHEDULED → SAMPLE_RECEIVED
└─ MORE_INFO → (retour producteur) → UNDER_REVIEW
└─ REJECTED

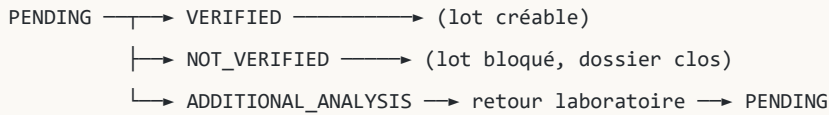
DRAFT est un brouillon producteur, invisible de Kounouz jusqu'à sa soumission.

Échantillon

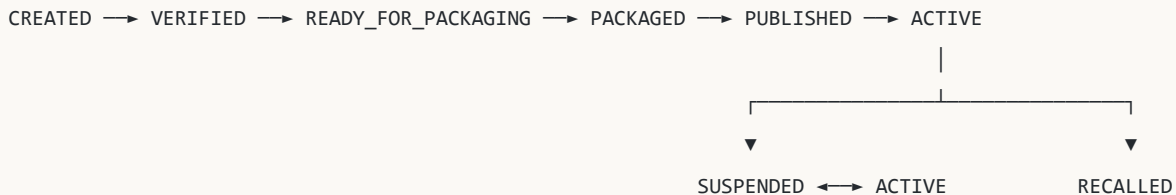
COLLECTED → SEALED → IN_TRANSIT → RECEIVED → SENT_TO_LAB → UNDER_ANALYSIS → ANALYSIS_RECEIVED

Un échantillon ne peut passer en transport que s'il est **scellé**.

Vérification



Lot



Produit et QR

Produit : DRAFT → READY → ACTIVE → SUSPENDED / ARCHIVED
QR : GENERATED → ACTIVE → SUSPENDED / DEACTIVATED

Règles d'or

- personne ne passe directement de la demande producteur au produit ;
- seul un échantillon contrôlé entre dans le flux laboratoire ;
- seul **VERIFIED** crée un lot ;
- seul un lot vérifié **et emballé** devient un produit commercial ;
- seul un produit publiable reçoit un QR actif ;
- suspendre un lot ou un produit **change immédiatement** le résultat public ;
- chaque changement d'état sensible est horodaté et attribué à un acteur ;
- les boutons de l'interface découlent des permissions et de l'état courant : aucune action affichée ne sera rejetée par le serveur.

18. Sécurité

Défense en profondeur

Toute requête traverse quatre contrôles successifs, **tous côté serveur** :

1. Limitation de débit → rejet avant tout travail
2. Authentification → jeton JWT valide
3. Autorisation (RBAC) → le rôle est-il autorisé ?
4. Propriété + état → la ressource lui appartient-elle,
la transition est-elle légale ?

Le frontend est une couche de présentation : **il n'est jamais une frontière de sécurité.**

Authentification

- jetons d'accès courts (15 min) + jetons de rafraîchissement (7 jours) révocables ;
- mots de passe stockés en **hash bcrypt** — jamais en clair ;
- **authentification à deux facteurs** disponible (activation, désactivation, connexion 2FA) ;
- changement d'e-mail et de mot de passe, suppression de compte ;
- les tentatives de connexion sont **limitées en débit**.

Limitation de débit

Route	Plafond
POST /api/auth/login	10 / minute
POST /api/auth/2fa/login	10 / minute
POST /api/auth/register	5 / minute
GET /api/verify/* (public)	60 / minute
Toutes les autres routes	120 / minute (configurable)
/health , /ready	non limitées

Cloisonnement des données

- la propriété est **déduite du jeton**, jamais d'un `producer_id` fourni par le client ;
- un producteur ne peut atteindre les données d'un autre producteur ;
- un agent ne voit que ses propres échantillons et missions ;
- un **consommateur authentifié ne peut atteindre aucune fiche interne** (échantillon, vérification, demande) : refus au niveau de la route **et** du service ;
- la vérification publique passe par un **modèle de lecture dédié** avec allowlist, jamais par les tables internes.

Fichiers et documents

Les bulletins d'analyse, preuves de collecte et documents producteurs sont stockés dans un volume dédié, avec des noms de fichiers générés côté serveur. Les documents producteurs sensibles sont servis par un point d'accès authentifié (`/producer-documents/:id/file`) et non par un chemin public.

Configuration de production

Variable	Rôle
<code>JWT_ACCESS_SECRET</code> , <code>JWT_REFRESH_SECRET</code>	Obligatoires — le démarrage échoue si absents
<code>CORS_ORIGINS</code>	Origines autorisées ; vide = tout autoriser (développement uniquement)
<code>DATABASE_URL</code>	Connexion PostgreSQL
<code>PUBLIC_APP_URL</code>	URL encodée dans les QR imprimés
<code>KOUNOUZ_COMMISSION_RATE</code>	Taux de commission
<code>THROTTLE_TTL</code> , <code>THROTTLE_LIMIT</code>	Plafond global de débit

Aucun secret n'est présent dans le code du frontend ni versionné : `.env` est exclu du dépôt.

19. Déploiement pas à pas

Prérequis

- Docker et Docker Compose
- 2 Go de RAM disponibles

A. Récupérer la configuration

```
cp .env.deploy.example .env
```

B. Générer les secrets JWT

```
node -e "console.log(require('crypto').randomBytes(48).toString('hex'))"
```

Lancer la commande **deux fois** et renseigner dans `.env` :

```
JWT_ACCESS_SECRET=<première valeur>
JWT_REFRESH_SECRET=<seconde valeur>
POSTGRES_PASSWORD=<mot de passe solide>
```

La pile **refuse de démarrer** si les secrets JWT sont absents : c'est volontaire, pour éviter une mise en production avec les valeurs d'exemple.

C. Fixer l'URL publique

```
PUBLIC_APP_URL=https://kounouzalafiya.com
CORS_ORIGINS=https://kounouzalafiya.com
```

À faire avant toute impression de QR : `PUBLIC_APP_URL` est l'adresse encodée dans les QR codes imprimés.

D. Démarrer la pile

```
docker compose up -d --build
```

Trois conteneurs démarrent :

Service	Rôle	Port
kounouz-postgres	Base de données	5433 (local)
kounouz-backend	API NestJS	3000
kounouz-frontend	nginx + bundle React	80

Les **migrations sont appliquées automatiquement** au démarrage du backend (`prisma migrate deploy` — jamais destructif).

E. Vérifier que la pile répond

```
curl http://localhost:3000/health
curl http://localhost:3000/ready
```

Réponses attendues :

```
{"status":"ok","uptime":27,"timestamp":"..."}
{"status":"ready","checks":{"database":"up"},"timestamp":"..."}
```

F. Peupler les données de démonstration (optionnel)

```
docker compose exec backend npx tsx prisma/seed.ts
```

À ne pas exécuter sur une base de production contenant des données réelles.

G. Lancer les tests d'acceptation

```
node scripts/acceptance.mjs
```

H. Ouvrir l'application

Adresse	Contenu
<code>http://localhost/</code>	Site public
<code>http://localhost/connexion</code>	Connexion aux portails
<code>http://localhost/verify/KZ-QR-2026-000001</code>	Vérification publique
<code>http://localhost:3000/api/docs</code>	Documentation Swagger de l'API

Ports déjà occupés

Si un port est pris, ajuster dans `.env` :

```
FRONTEND_PORT=8088
BACKEND_PORT=3001
POSTGRES_PORT=5433
```

Avant la mise en production réelle

- ☐ Secrets JWT générés et propres à la production
- ☐ Mot de passe PostgreSQL solide
- ☐ `CORS_ORIGINS` limité au domaine réel
- ☐ `PUBLIC_APP_URL` correspondant au domaine réel
- ☐ HTTPS/TLS actif (termination TLS devant nginx)
- ☐ Port PostgreSQL **retiré** de `docker-compose.yml` (base non joignable depuis Internet)
- ☐ Port backend retiré si nginx relaie déjà `/api`
- ☐ Sauvegarde automatique de la base **et restauration testée**
- ☐ Sauvegarde du volume `kounouz_uploads` (preuves et bulletins)
- ☐ RPO / RTO documentés
- ☐ Supervision de `/health` et `/ready`
- ☐ Tests d'acceptation passés sur l'environnement cible

20. Comptes et données de démonstration

Créés par `prisma/seed.ts`.

Rôle	Identifiant	Mot de passe
Admin	admin@kounouzalafiya.com	Admin123!
Équipe de Vérification	verification@kounouzalafiya.com	Verif123!
Agent Terrain	agent@kounouzalafiya.com	Agent123!
Producteur	producteur@kounouzalafiya.com	Prod123!
Producteur (2)	fatma.trabelsi@kounouzalafiya.com	Prod123!
Consommateur	client@kounouzalafiya.com	Client123!

Ce sont des comptes de **démonstration**. À supprimer ou à réinitialiser avant toute mise en production réelle.

QR codes de démonstration

Code	Statut public	Produit
KZ-QR-2026-000001	VERIFIED	Miel de Sedra Premium 500 g
KZ-QR-2026-000002	SUSPENDE	Miel de Fleurs Sauvages 250 g

À tester directement : <http://localhost/verify/KZ-QR-2026-000001>

Conventions de codification

Entité	Format	Exemple
Demande	KZ-REQ-AAAA-NNNNNN	KZ-REQ-2026-000014
Échantillon	SM-AAAA-NNNNNN	SM-2026-000031
Analyse	LAB-AAAA-NNN	LAB-2026-031
Vérification	VT-AAAA-NNN	VT-2026-006
Lot	KZ-BAT-AAAA-NNN	KZ-BAT-2026-031
QR	KZ-QR-AAAA-NNNNNN	KZ-QR-2026-000001

21. Scénario complet de bout en bout

Ce scénario parcourt **toute la chaîne de confiance**, de la demande du producteur jusqu'au scan du consommateur et à la suspension. Il correspond au test d'acceptation du cahier des charges.

Durée : environ 20 minutes. Gardez plusieurs onglets ou navigateurs ouverts pour éviter de vous reconnecter à chaque changement de rôle.

Acte 1 — Le producteur demande une vérification

1. Ouvrir `http://localhost/connexion`.
2. Se connecter avec `producteur@kounouzalafiya.com` / `Prod123!`.
3. Vous arrivez sur le tableau de bord producteur.
4. Aller dans **Mes demandes** → **Nouvelle demande**.
5. Renseigner : type de miel (ex. *Miel de Thym*), quantité estimée, période de récolte, rucher concerné.
6. **Observer** : aucun champ ne permet de joindre un résultat de laboratoire. C'est voulu — le producteur ne fournit pas la preuve, Kounouz la produit.
7. Soumettre.

✅ **Attendu** : la demande apparaît au statut **Soumise**, avec un numéro `KZ-REQ-...`.

Acte 2 — Kounouz examine la demande

8. Se connecter avec `verification@kounouzalafiya.com` / `Verif123!`.
9. Aller dans **Revue des demandes**. La nouvelle demande y figure.
10. L'ouvrir, examiner les informations du producteur et du rucher.
11. Choisir **Accepter**, puis planifier la collecte :
 - méthode **Visite Kounouz** (`KOUNOUZ_VISIT`) ou **Livraison producteur** (`PRODUCER_DELIVERY`) ;
 - pour une visite : assigner un agent terrain et un créneau.

✅ **Attendu** : la demande passe à **Collecte planifiée**. Le producteur reçoit une notification `REQUEST_ACCEPTED`.
L'agent reçoit `COLLECTION_ASSIGNED`.

Acte 3 — L'agent terrain collecte l'échantillon

12. Se connecter avec `agent@kounouzalafiya.com` / `Agent123!` (*l'interface est optimisée pour mobile — réduisez la fenêtre pour voir le rendu réel du terrain*).
13. Aller dans **Mes missions** : la mission assignée apparaît.
14. Ouvrir la mission, **Démarrer la collecte**.
15. Dans l'assistant : saisir la quantité prélevée, la date et l'heure, la position, ajouter des photos et des notes.
16. Valider la collecte.

✅ **Attendu** : un échantillon est créé avec un identifiant unique `SM-2026-.....`, au statut **Collecté**.

Essayez de tricher : reconnectez-vous en producteur et cherchez un bouton pour créer un échantillon. Il n'existe pas. Un appel direct à l'API (`POST /api/samples`) renvoie **403**.

Acte 4 — Le scellé sécurisé

17. Toujours en agent, sur l'échantillon : **Enregistrer le scellé**.
18. Saisir l'identifiant du scellé Kounouz et joindre la preuve photo.

✓ **Attendu** : l'échantillon passe à **Scellé**. Le scellé est unique et lié à cet échantillon seul.

Acte 5 — La chaîne de custody

19. Aller dans **Traçabilité** et enregistrer le transport de l'échantillon.

20. Ouvrir le détail : l'historique des événements s'affiche.

✓ **Attendu** : chaque étape est un événement horodaté et attribué à un acteur. **Aucun événement ne peut être supprimé ni réécrit** — une correction ajoute un nouvel événement.

Acte 6 — Réception et analyse laboratoire

21. Se reconnecter en **vérificateur**.

22. **Gestion des échantillons** : réceptionner l'échantillon, puis l'envoyer au laboratoire.

23. Aller dans **Laboratoire**, ouvrir le dossier d'analyse.

24. Saisir les paramètres normés du bulletin (humidité, HMF, diastase, conductivité, sucres, antibiotiques...) avec valeur, unité et plage de référence, puis joindre le bulletin original.

25. Marquer l'analyse comme terminée.

✓ **Attendu** : l'échantillon passe à **Analyse reçue**. Le producteur reçoit `ANALYSIS_COMPLETED`. Les plages de référence sont **figées** sur chaque ligne : si le référentiel évolue, les bulletins déjà émis restent lisibles tels qu'ils ont été validés.

Acte 7 — L'échantillon de référence

26. Aller dans **Échantillons de référence**.

27. Enregistrer l'échantillon de référence conservé par Kounouz : lieu de stockage, conditions, durée de conservation.

✓ **Attendu** : la fiche est liée à l'échantillon contrôlé. Cette donnée est **strictement interne** et n'apparaîtra jamais sur la page publique.

Acte 8 — La décision de vérification

28. Aller dans **Décision de vérification**. Le dossier est prêt.

29. Consulter la synthèse : demande, échantillon, scellé, custody, bulletin, échantillon de référence.

30. Remplir la grille d'évaluation (authenticité, physico-chimie, pollen, antibiotiques, appréciation globale).

31. Choisir **VÉRIFIÉ** et confirmer.

✓ **Attendu** : la décision enregistre le décideur, l'horodatage, le code `VT-2026-...` et les références de preuve. Le producteur reçoit `VERIFICATION_RESULT`. Une entrée apparaît au **journal d'audit**.

Essayez de tricher : en agent terrain, cherchez cet écran. Il n'existe pas. Un appel direct `POST /api/verifications` renvoie **403**.

Acte 9 — Le lot vérifié

32. Aller dans **Lots vérifiés** → **Créer un lot** depuis la vérification.

33. Renseigner le type de miel, l'origine et la période de production.

✓ **Attendu** : un lot `KZ-BAT-...` est créé. Le producteur reçoit `BATCH_CREATED`.

Point de contrôle clé : reprenez le scénario avec une décision **NON VÉRIFIÉ** — la création de lot est **impossible**. C'est la garantie centrale du modèle.

Acte 10 — L'emballage Kounouz

34. Aller dans **Emballage**.

35. Enregistrer l'opération : format de pot, quantité, lot d'emballage, opérateur.

✓ **Attendu** : le lot passe à **Emballé**. Le producteur n'intervient pas : l'emballage est une opération Kounouz.

Acte 11 — Le produit et ses SKU

36. Aller dans **Produits** → **Créer un produit** depuis le lot emballé.

37. Renseigner le nom commercial, la description, la catégorie, les images.

38. Créer les déclinaisons : 250 g, 500 g, 1 kg — chacune avec son SKU, son prix et son stock.

39. Publier le produit.

✓ **Attendu** : le produit apparaît dans le catalogue public. Le producteur reçoit `PRODUCT_PUBLISHED`. Chaque SKU conserve le lien vers le lot et la traçabilité.

Acte 12 — La génération des QR

40. Aller dans **Génération de QR**.

41. Lancer une campagne pour le produit : chaque pot reçoit un QR unique.

42. Aller dans **Gestion des QR** : rechercher, filtrer, inspecter, exporter.

43. Ouvrir l'image d'un QR (`/api/verify/<qrId>/image`) — c'est celle à imprimer.

✓ **Attendu** : chaque QR est unique et actif, relié au produit, au SKU et au lot.

Acte 13 — Le scan du consommateur

44. **Se déconnecter complètement** (ou utiliser une fenêtre de navigation privée) : le consommateur n'est pas authentifié.

45. Ouvrir `http://localhost/verify/KZ-QR-2026-000001` (ou le QR que vous venez de générer).

46. La page de vérification publique s'affiche :

- bandeau **Vérifié par Kounouz** ;

- produit, image, gamme ;
- producteur, exploitation, région ;
- code de lot, type de miel, date de production, origine ;
- date de vérification ;
- **résultats du laboratoire** : paramètres normés avec valeur, unité et plage de référence, sous un panneau dépliant.

✓ **Attendu — et c'est le point essentiel** : la page **ne contient aucune** note de décision, note interne, conclusion d'analyste, information sur l'échantillon de référence, détail de custody, identifiant de scellé ni donnée d'employé.

47. Tester aussi le bouton **Signaler une étiquette** : il ouvre une alerte anti-contrefaçon interne.

48. Tester un QR inexistant : <http://localhost/verify/QR-INVENTE-123> → page « QR invalide ». **Le scan est malgré tout journalisé** comme signal.

Acte 14 — Les statistiques

49. Se connecter en **admin** (admin@kounouzalafiya.com / [Admin123!](#)).

50. **Statistiques** → **Scans** (</admin/analyses/scans>) : votre scan apparaît — volume, validité, répartition temporelle.

51. **Statistiques** → **Alertes** (</admin/analyses/alertes>) : le signalement d'étiquette et le scan sur QR inconnu figurent en alertes internes.

52. **Statistiques** → **Analytique métier** (</admin/analyses/verification>) : entonnoir de vérification, lots, produits, tendances.

✓ **Attendu** : chaque scan est compté et rattaché au bon QR, produit et lot.

Acte 15 — La suspension : le test décisif

C'est la démonstration la plus importante de la plateforme.

53. En **admin** ou en **vérificateur**, ouvrir le lot ou le produit correspondant au QR que vous venez de scanner.

54. Le passer en **Suspendu**.

55. **Sans rien réimprimer**, recharger la page publique <http://localhost/verify/<le même QR>> .

✓ **Attendu** : la page affiche désormais **Suspendu**. L'identifiant imprimé sur le pot n'a pas changé d'un caractère, mais le message public a changé immédiatement.

56. Essayer avec un lot **Rappelé** : la page affiche **Rappelé**, qui prime sur toute autre information.

57. Restaurer le statut **Actif** : la page publique redevient **Vérifié**.

C'est tout le sens de « le QR n'est pas la source de vérité, la base l'est ». Un rappel produit est opérationnel **immédiatement**, sans logistique d'étiquetage.

Acte 16 — Les ventes et les gains

58. Depuis le site public, ajouter le produit au panier et passer une commande.

59. Se connecter en **producteur** → **Ventes**.

60. Consulter **Mes gains** : unités vendues par SKU, chiffre d'affaires brut, commission Kounouz, net producteur.

61. Consulter **Règlements** : périodes et statut de paiement.

✅ **Attendu** : les montants sont calculés par SKU, avec le taux de commission issu de la configuration — jamais codé en dur.

Acte 17 — L'audit

62. En **admin** → **Journal d'audit** (</admin/journal>).

63. Retrouver la trace de chaque action sensible du scénario : acceptation de la demande, création de l'échantillon, scellé, saisie d'analyse, **décision de vérification**, création du lot, emballage, création du produit, génération de QR, suspension.

✅ **Attendu** : chaque entrée porte un acteur, un horodatage, l'entité visée et le changement d'état.

Récapitulatif du scénario

Étape	Acteur	Résultat vérifiable
Demande de vérification	Producteur	KZ-REQ-... au statut Soumise
Revue et acceptation	Vérification	Collecte planifiée
Collecte	Agent Terrain	SM-... Collecté
Scellé	Agent Terrain	Scellé unique, échantillon Scellé
Chaîne de custody	Agent Terrain	Événements en ajout seul
Analyse	Vérification	Bulletin avec paramètres normés
Échantillon de référence	Vérification	Fiche interne liée
Décision	Vérification	VT-... VÉRIFIÉ, audité
Lot	Vérification	KZ-BAT-...
Emballage	Vérification	Lot Emballé
Produit + SKU	Vérification	Produit publié, SKU 250 g / 500 g / 1 kg
QR	Vérification	KZ-QR-... actif
Scan	Consommateur	Page publique, sans donnée interne
Statistiques	Admin	Scan comptabilisé
Suspension	Admin / Vérification	Page publique modifiée sans réimpression
Ventes	Producteur	Gains par SKU avec commission
Audit	Admin	Trace complète

22. Tests d'acceptation automatisés

Un script vérifie automatiquement les règles non négociables du cahier des charges. À lancer après chaque déploiement.

```
node scripts/acceptance.mjs
```

Sur un port personnalisé :

```
API_URL=http://localhost:3001/api node scripts/acceptance.mjs
```

Ce qui est vérifié (25 contrôles)

Section	Contrôles
1. Exploitation	<code>/health</code> répond ; <code>/ready</code> confirme la base
2. Authentification	Connexion des 5 types d'utilisateurs
3. Permissions	Non authentifié rejeté ; producteur ne crée pas d'échantillon, ni de lot, ni de produit ; agent ne décide pas ; agent ne lit pas l'audit ; producteur ne gère pas les utilisateurs
4. Cloisonnement consommateur	Consommateur rejeté sur échantillon, vérification et demande ; vérificateur conserve l'accès
5. Vérification publique	Le QR résout ; aucun champ interne exposé ; notes de décision absentes ; bulletin normalisé ; statut dérivé de l'état courant ; QR inconnu → 404
6. Limitation de débit	La force brute sur la connexion est bloquée (429)

Résultat attendu

Bilan : 25 réussi(s), 0 échec(s)
Déploiement conforme au cahier des charges.

Le script sort en **code 1** dès qu'un contrôle échoue : il peut servir de garde-fou en intégration continue.

État vérifié sur cette version

Tous les contrôles passent. Ont également été validés manuellement :

- construction du backend et du frontend sans erreur de typage ;
- construction des images Docker et démarrage de la pile complète ;
- application automatique des 12 migrations au démarrage ;
- repli SPA de nginx (un scan de QR ne renvoie pas un 404 serveur) ;
- relais `/api` par nginx ;
- désactivation d'un QR → la page publique change immédiatement, puis restauration.

23. Exploitation au quotidien

Commandes utiles

```
# État de la pile
docker compose ps

# Journaux
docker compose logs -f backend
docker compose logs -f frontend

# Redémarrer un service
docker compose restart backend

# Arrêter (les données sont conservées)
docker compose down

# Arrêter ET supprimer les données ⚠️ destructif
docker compose down -v
```

Sauvegarde

```
# Base de données
docker compose exec postgres pg_dump -U kounouz kounouz_alafiya > sauvegarde.sql

# Restauration
cat sauvegarde.sql | docker compose exec -T postgres psql -U kounouz -d kounouz_alafiya
```

Sauvegarder **également** le volume `kounouz_uploads` : il contient les bulletins d'analyse et les preuves de collecte, qui sont des pièces de traçabilité.

Supervision

Sonde	À surveiller
<code>GET /health</code>	Le process répond (liveness)
<code>GET /ready</code>	La base est joignable (readiness) — renvoie <code>503</code> sinon

À suivre également : taux d'erreurs 5xx, latence de l'API, santé et saturation de la base, volume de scans par minute, taux de QR invalides, dossiers de vérification en attente et échantillons bloqués dans un état.

Mise à jour

```
git pull
docker compose up -d --build
node scripts/acceptance.mjs
```

Les migrations en attente sont appliquées automatiquement au redémarrage.

24. Hors périmètre Phase 1

Conformément au cahier des charges, **ne font pas partie** de cette phase :

- décision automatisée par intelligence artificielle ;
- blockchain ;
- SaaS en marque blanche ;
- portail laboratoire séparé ;
- portail transporteur séparé ;
- application mobile native ;
- refonte majeure du site public ;
- accusation automatique de contrefaçon fondée sur un score de scan.

Prochaines étapes naturelles

1. Terminaison TLS et nom de domaine de production.
2. Sauvegardes automatisées avec restauration testée périodiquement.
3. File de messages et workers dédiés (l'architecture événementielle est prête : les notifications sont déjà générées à partir d'événements métier).
4. Cache Redis pour la limitation de débit distribuée, lorsque plusieurs instances d'API seront déployées.
5. Couche d'assistance IA **en lecture seule** (résumés de dossier, explication des pièces manquantes), sans jamais toucher à l'autorité de décision.

Principe final

REQUÊTE → ÉCHANTILLON CONTRÔLÉ → LABORATOIRE → ÉCHANTILLON DE RÉFÉRENCE → DÉCISION DE VÉRIFICATION → LOT VÉRIFIÉ → EMBALLAGE → PRODUIT → QR → VÉRIFICATION PUBLIQUE

Aucun écran, aucune sortie d'IA, aucun worker, aucune intégration et aucun service externe ne peut contourner cette séquence. Le modèle de confiance de Kounouz Alafiya est appliqué par le backend, les contraintes de base de données, les règles métier, les machines à états, le journal d'audit et des décisions humaines contrôlées.

